

1. Explain the difference between authentication and authorization.

Ans: Authentication is the process of verifying a user's identity by checking credentials such as a username and password. Authorization determines what an authenticated user is allowed to access or perform within the application. Authentication answers "who are you?", while authorization answers "what are you allowed to do?"

2. Why should passwords never be stored in plain text?

Ans: Passwords should never be stored in plain text because anyone who gains access to the database or files can read them directly. Storing passwords as hashes protects user credentials and reduces the risk of unauthorized access if the data is compromised.

3. What is the purpose of password hashing?

Ans: Password hashing converts a password into a fixed-length encrypted hash using a one-way algorithm such as SHA-256. The original password cannot be easily recovered from the hash. During login, the entered password is hashed again and compared with the stored hash to verify the user's identity.

4. How does duplicate login prevention improve security?

Ans: Duplicate login prevention ensures that the same user account cannot be logged in from multiple devices or sessions simultaneously. This reduces the risk of account misuse, unauthorized access, session conflicts, and impersonation.

5. Suggest two additional security improvements for your application.

Ans: 1. Encrypt all client-server communication using SSL/TLS to protect data from interception.

2. Implement two-factor authentication (2FA) or one-time passwords (OTP) to provide an additional layer of security during user login.